SHIELD-AI Field Findings

Findings from Milestone 3 field validation, staged for the next framework cycle. This document is the holding point where assessment engagements record what the framework's method and controls need. The monthly deep-review cron considers this file when drafting the next cycle. The v1.10 cycle (September 1, 2026) adopted FF-01, FF-06, and FF-07 into the assessment methodology (Section 8 and Phase 2 evidence collection).

How to use this file

- Each entry names the finding, the evidence, and the proposed framework delta.
- Entries are tagged `pending` until a cycle adopts them, then `adopted`.
- A new field finding is appended, never overwriting history.

FF-01: The configuration-assertion trap

- **Status:** adopted (v1.10, September 1, 2026)
- **Source:** case-studies/2026-08-reference-implementation.md, findings F4
- **Finding:** a deployment can assert any posture in a configuration file (deployment.json in the reference implementation) and every decision then evaluates as if the posture were real. Evidence scores reward the assertion, not the operation.
- **Proposed delta:** the assessment guide's Phase 2 artifact lists should require operational evidence (logs, attestation outputs, exercised runs) for any control scored at L3 or above, and explicitly downgrade configuration-claim-only evidence to L1/L2.
- **Adoption note:** applied to the assessment guide Section 8 scoring method and Phase 2 evidence collection (v1.10).

FF-02: Weakest-link scoring conflates “not assessed” with “L1”

- **Status:** pending
- **Source:** case-studies/2026-08-reference-implementation.md, section 3.1
- **Finding:** pillar maturity as the minimum control score treats an unevaluated control (its action kind never occurs in the deployment) the same as a control that was evaluated and failed. A deployment that never runs evaluation harnesses is scored L1 on EE-04/EE-08 without ever being tested there.
- **Proposed delta:** add an explicit “not exercised” evidence state to the scoring guide (Section 8), distinct from evidence 1-2, so reports can distinguish “fails” from “out of scope for this deployment”.

FF-03: Validation suites need a control-coverage map

- **Status:** pending
- **Source:** case-studies/2026-08-reference-implementation.md, finding F3
- **Finding:** the reference implementation’s e2e matrix exercises 12 of 59 controls with runtime deny observations; the other 47 are evaluated but never deny-observed. “Continuously verified” claims currently cover only the exercised subset, and nothing in the framework says so.
- **Proposed delta:** the framework should define a minimum exercised-control ratio (e.g. 50% of controls with runtime observation) before a deployment may claim continuously verified enforcement, and the guide should ship a coverage-map template.

FF-04: Positive controls belong in the method

- **Status:** pending
- **Source:** case-studies/2026-08-reference-implementation.md, allow_approved_transfer

- **Finding:** the approved high-risk transfer passing all 59 controls was the strongest single proof that the full evaluation path works (deny rules for unexercised kinds do not false-positive). The guide's method has no positive-control requirement.
- **Proposed delta:** Phase 2 of the assessment methodology should require at least one positive control (an action that must pass every control) per engagement, alongside the deny cases.

FF-05: Substitution disclosure for reference implementations

- **Status:** pending
- **Source:** case-studies/2026-08-reference-implementation.md, finding F5
- **Finding:** the reference implementation substitutes framework mechanisms (sidecar-minted provenance for TP-12 model-turn signatures, config-file identities for IAM-01 SPIFFE). The substitution is documented in the reference README but nothing in the framework requires it to be declared.
- **Proposed delta:** the assessment guide gains a "reference-implementation substitution disclosure" requirement: any deployment substituting a framework mechanism must declare it and mark the affected controls accordingly.

FF-06: Independent verification applies to first-party components too

- **Status:** adopted (v1.10, September 1, 2026)
- **Source:** case-studies/2026-08-reference-implementation.md, finding F6
- **Finding:** the sidecar self-attests its own gateway and audit claims. This mirrors the GRM-04 third-party lesson (the Irregular evaluation harness failure: self-attested isolation) but for first-party components, where the framework has no equivalent requirement.
- **Proposed delta:** extend the attestation requirement language (EE-08, GRM-04) to first-party enforcement components: claims about the enforcement boundary must be independently verifiable, not merely asserted by the component itself.

- **Adoption note:** applied to the assessment guide Section 8 attestation requirements and the EE-08/GRM-04 guidance cross-references (v1.10).

FF-07: Validation coverage maps catch config-schema drift

- **Status:** adopted (v1.10, September 1, 2026)
- **Source:** case-studies/2026-08-reference-implementation.md, finding F11
- **Finding:** the coverage expansion only succeeded by asserting per-control deny markers, and that assertion immediately exposed a config-schema drift (agent configs declared `path_writable` at the agent root while EE-05/EE-07 evaluate `agent.config.path_writable`), which had silently disabled a control's enforcement branch in the reference deployment. A claim-based test would have kept passing; a marker-asserting test could not.
- **Proposed delta:** the assessment guide's Phase 2 evidence collection should include a schema-drift check between deployment configuration and the policy input model, and validation suites should assert the deny message of every control they claim to exercise.
- **Adoption note:** applied to the assessment guide Phase 2 evidence collection and the reference-implementation validation guidance (v1.10).

First compiled: August 22, 2026 (Milestone 3 field validation, case study 2026-08-reference-implementation).